

ARG LEADS TRACKER

Adversarial Security Review
and Production Go-Live Plan

AR

LAUNCH DECISION: HOLD

The application should not be promoted as finally live until the four launch blockers in this report are remediated and independently re-tested.

Prepared for	Al Ras Steel management and CRM implementation team
Assessment date	30 July 2026
Application	ARG Leads Tracker CRM
Production URL	https://argleadstracker.vercel.app/
Assessment type	Adversarial pre-launch security and operational readiness review
Classification	Confidential - Internal Use

Purpose

This report records the confirmed results of the pre-launch adversarial review, identifies what is still missing, and provides the implementation and verification sequence required before production approval. It is intentionally written as both a management decision document and an engineering runbook.

Prepared from local source review, automated tests, build validation, configuration inspection, and read-only production probes. No production data was modified during the assessment.

1. Executive Summary

The CRM has a solid functional base: automated checks passed, role-boundary tests passed, the production site correctly rejected several unauthenticated data endpoints, and obvious secret files were not publicly retrievable. However, the review confirmed four launch-blocking security weaknesses and several high-priority operational gaps.

4 Launch blockers	6 Additional security gaps	3 Automated suites passed
----------------------	-------------------------------	------------------------------

Confirmed launch blockers

- Production exposes application source files including server.js, supabase-client.js, and package.json.
- The market-intelligence cron endpoint can execute without authentication when CRON_SECRET is missing.
- PMR voice-note media is served before authentication and ownership checks.
- Normal production data access defaults to the Supabase service-role key, bypassing Row Level Security.

Positive assurance obtained

- Type and static checks passed.
- The full automated test suite passed, including role access, activity, upload, and AI Assistant coverage.
- The production build completed successfully.
- Unauthenticated settings, leads, users, and AI-history requests returned HTTP 401.
- The .env file, data database file, and .git configuration were not publicly accessible.
- HSTS is enabled on production.

Management recommendation: authorize a short security-hardening release, complete staging validation against the real production Supabase project, and approve production only after every P0 gate in Section 7 has evidence attached.

2. Scope and Method

The assessment covered the following areas:

Area	What was examined
Application code	Server routing, static serving, authentication order, authorization helpers, error handling, uploads, AI and transcription limits.
Identity and access	Admin and Salesman role boundaries, unauthenticated endpoints, token handling, service-role usage, and object ownership.
Production perimeter	Publicly accessible files, security headers, health responses, protected endpoints, and current deployment status.
Data protection	Supabase access mode, expected RLS behavior, private media delivery, secrets handling, and upload controls.
Operational readiness	Build and tests, deployment freshness, migrations, backups, observability, rate limiting, incident readiness, and release control.

Assessment limitations

- The connected Supabase project was not the production CRM database. Live RLS policies, backup settings, and production migrations could not be independently verified.
- Production runtime logs could not be inspected because the available Vercel log connection returned an authorization error.
- The cron endpoint was not invoked because doing so would trigger production side effects.
- This was a targeted pre-launch adversarial review, not a formal third-party penetration test or compliance certification.

Readiness classification

Status	Meaning	Current result
READY	No unresolved launch blockers; evidence complete.	
CONDITIONAL	Only accepted low-risk items remain with dated owners.	
HOLD	One or more critical/high launch blockers remain.	CURRENT

3. Confirmed Findings and Remediation

F-01 CRITICAL Production source-code disclosure

Observed evidence. Read-only production probes returned HTTP 200 for /server.js, /supabase-client.js, and /package.json. The server static handler resolves broad repository paths instead of serving from a dedicated public directory.

Business impact. Attackers can study internal routes, authorization assumptions, environment-variable names, data flows, and implementation weaknesses. Even without an exposed secret, this materially lowers the cost of a targeted attack.

Required implementation.

- Create a dedicated public directory containing only approved browser assets.
- Replace the broad static route with an explicit allowlist for index.html, CSS, client bundles, service worker, manifest, icons, and required public media.
- Return HTTP 404 for server files, API modules, package metadata, migrations, scripts, data directories, dotfiles, environment files, source maps, and test files.
- Add automated negative tests for at least /server.js, /package.json, /vercel.json, /.env, /.git/config, /data/db.json, and /supabase/migrations/.

Acceptance test. Every forbidden path returns 404 with no file content; the normal app, service worker, manifest, and static assets still load successfully.

F-02 CRITICAL Cron endpoint fails open when CRON_SECRET is absent

Observed evidence. The market-intelligence cron route only enforces its bearer secret when CRON_SECRET is non-empty. Production did not have CRON_SECRET configured.

Business impact. An unauthenticated party may be able to trigger integration calls, consume quotas, insert records, generate logs, or create repeated workload and cost.

Required implementation.

- Change the route to fail closed: if CRON_SECRET is missing, return 503 and do not execute any job code.
- Require an exact constant-time comparison of the Authorization bearer token.
- Create a new random production secret of at least 32 bytes and store it only in Vercel encrypted environment variables.
- Configure the scheduled job to send the secret and add rate limiting plus idempotency for each schedule window.
- Log job start, completion, duration, record counts, and failure reason without logging the secret.

Acceptance test. Missing, blank, malformed, and incorrect credentials all fail without side effects; only the scheduled request succeeds once per intended window.

3. Confirmed Findings and Remediation - Continued

F-03 HIGH Voice-note media is served before authentication

Observed evidence. The PMR voice-note GET route is handled before current-user authentication. A random nonexistent ID returned 404 rather than 401, confirming that the route bypasses the normal authentication gate.

Business impact. Anyone possessing or discovering a valid media identifier may retrieve confidential customer or salesman recordings.

Required implementation.

- Move the route behind authentication.
- Resolve the voice-note record, associated lead, and owner before opening the file.
- For Salesman users, enforce lead ownership or assigned-territory authorization. Permit Admin only under the existing role policy.
- Store media in a private Supabase bucket and issue signed URLs with a five-minute maximum lifetime.
- Set Cache-Control: private, no-store and log successful and denied downloads.

Acceptance test. Anonymous requests return 401; unauthorized authenticated users return 403; authorized users can retrieve only their permitted recording; signed URLs expire.

F-04 HIGH Service-role access bypasses RLS for normal requests

Observed evidence. The server data helper selects the Supabase service-role client whenever it is configured. Service-role requests bypass Row Level Security.

Business impact. A missed manual filter in any endpoint can become a cross-salesman data leak or unauthorized modification. Database defense in depth is effectively disabled.

Required implementation.

- Change the default data path to use the authenticated user's Supabase access token.
- Create a separate, explicit serviceRole operation for bootstrap, controlled administration, migrations, and the authenticated cron only.
- Inventory every API route and document the expected Admin and Salesman authorization rule.
- Apply production RLS policies to every business table and private storage bucket.
- Test with one Admin and at least two Salesmen assigned to different territories and leads.

Acceptance test. Each Salesman can list, read, update, upload to, and query only permitted records; Admin access matches policy; direct Supabase API calls cannot bypass the same rule.

F-05 HIGH Missing browser security headers

Observed evidence. Production provides HSTS but did not return Content-Security-Policy, frame protection, X-Content-Type-Options, Referrer-Policy, or Permissions-Policy.

Business impact. The application has weaker protection against script injection, clickjacking, MIME confusion, referrer leakage, and unnecessary browser capabilities.

Required implementation.

- Add a tested CSP with default-src 'self', object-src 'none', base-uri 'self', form-action 'self', and frame-ancestors 'none'.
- Allow only the exact Supabase, map, font, image, and API origins required by the app.
- Add X-Content-Type-Options: nosniff, Referrer-Policy: strict-origin-when-cross-origin, X-Frame-Options: DENY, and a restrictive Permissions-Policy.
- Use CSP report-only mode in staging first, remove unsafe-inline where practical, then enforce in production.

Acceptance test. Browser tests show no CSP violations in normal workflows; external embedding is blocked; required microphone and geolocation behavior still works only on approved screens.

3. Confirmed Findings and Remediation - Continued

F-06 HIGH Insufficient durable rate limiting

Observed evidence. Rapid invalid login attempts did not receive HTTP 429. AI Assistant and transcription limits are stored in process memory, which is not reliable across serverless instances or restarts.

Business impact. Credential attacks, quota exhaustion, cost abuse, and denial of service may bypass instance-local controls.

Required implementation.

- Apply Vercel Firewall or a durable Redis/Supabase-backed limiter.
- Rate-limit login by IP and normalized account identifier, with progressive delay and alert thresholds.
- Add user and tenant limits for AI Assistant, transcription, exports, uploads, search, password recovery, and expensive reports.
- Return Retry-After and a safe error message; record security telemetry without storing raw credentials or voice content.

Acceptance test. Distributed requests across multiple instances still share the same limits; thresholds return 429 and recover after the intended window.

F-07 HIGH Browser-accessible refresh tokens and session storage

Observed evidence. The login response returns access and refresh tokens to JavaScript, and the client keeps the access token in sessionStorage.

Business impact. A successful script-injection attack can steal the session. Exposing a refresh token increases the duration and impact of token theft.

Required implementation.

- Prefer HttpOnly, Secure, SameSite cookies for session material.
- Add CSRF protection for all state-changing requests if cookies are used.
- Do not return refresh tokens to browser JavaScript unless the architecture demonstrably requires it.
- Shorten access-token lifetime, rotate refresh tokens, and revoke sessions on password or role changes.
- Pair the change with CSP enforcement and centralized output encoding.

Acceptance test. Tokens are absent from sessionStorage/localStorage and inaccessible to JavaScript; CSRF tests fail safely; logout and revocation invalidate the session.

F-08 MEDIUM Public health endpoint reveals infrastructure details

Observed evidence. The public health response identifies enabled integrations, Supabase administrative configuration, and AI model information.

Business impact. The information assists reconnaissance and reveals which third-party systems may be targeted or abused.

Required implementation.

- Return only a minimal public response such as {ok:true}.
- Move dependency and integration diagnostics to an authenticated Admin-only endpoint or monitoring platform.
- Ensure diagnostic responses never reveal secrets, project references, storage paths, or model configuration.

Acceptance test. Anonymous health responses reveal only availability; authorized operational staff can still access detailed diagnostics.

F-09

MEDIUM

Raw exception messages are returned to clients

Observed evidence. The global error path returns error.message in the HTTP response.

Business impact. Database, storage, and integration failures can disclose implementation details and provide attackers with useful diagnostics.

Required implementation.

- Generate a request ID for every request.
- Log full exceptions in structured server-side logs with secret redaction.
- Return a generic 500 response with the request ID.
- Allowlist safe validation and business-rule messages for expected 4xx errors.

Acceptance test. Forced failures expose no stack, SQL, provider, storage, or secret details to clients, while operators can locate the complete server-side event using the request ID.

3. Confirmed Findings and Remediation - Continued

F-10 **MEDIUM** **Uploaded documents are not malware-scanned**

Observed evidence. The application enforces file-size, type, filename, MIME, and basic signature checks. It does not scan accepted PDF or Office documents for malware or dangerous active content.

Business impact. A user may upload a malicious document that is later downloaded and opened by another employee.

Required implementation.

- Upload new files into a private quarantine path and mark them Pending Scan.
- Trigger an antivirus scanner or managed malware-scanning service.
- Make files downloadable only after a Clean result.
- Delete or isolate infected files and notify Admin without exposing the payload.
- Consider removing legacy .doc and .xls support if the business does not require macro-capable formats.

Acceptance test. Known test malware is blocked and quarantined; clean allowed documents become available; scan failures do not accidentally release the file.

Release and configuration gaps

Gap	Why it matters	Required evidence
Production is behind local work	The reviewed local workspace contains substantial changes not present in the current live deployment.	Clean commit, release tag, deployment SHA, and post-deploy smoke results.
Live Supabase project not verified	RLS, migrations, storage policy, backup, and restore status are unknown.	Correct project linked; schema and policies exported; RLS tests and restore test passed.
Pending migration not proven applied	Features may depend on schema not present in production.	Migration ledger and schema diff show no pending migration.
ADMIN_BOOTSTRAP_PASSWORD remains configured	A bootstrap credential should not remain after provisioning.	Secret removed or rotated; login and recovery process verified.
Production runtime logs unavailable	The team cannot prove error-free launch behavior or investigate incidents quickly.	Vercel log access, retention, alerting, and request-ID search demonstrated.
No documented restore drill	Backups that have never been restored are unproven.	Timed staging restore with row counts and checksum spot checks.
No formal incident runbook	Security and outage response may be delayed.	Named on-call contacts, severity rules, escalation, and communication templates.

4. What Is Still Missing Before Go-Live

Workstream	Pending deliverable	Priority	Suggested owner
Application perimeter	Static asset allowlist and source-file deny tests	P0	Backend lead
Scheduled jobs	Fail-closed CRON_SECRET authentication and idempotency	P0	Backend / DevOps
Private media	Authenticated ownership checks and signed voice-note URLs	P0	Backend lead
Database security	User-token data path, complete RLS, cross-user tests	P0	Supabase / Backend
Browser security	CSP and complete response-header policy	P0	Frontend / DevOps
Abuse protection	Durable distributed rate limiting	P0	DevOps / Backend
Release integrity	Clean tracked release and deployment provenance	P0	Release manager
Database readiness	Migration proof, backup policy, restore rehearsal	P0	Database owner
Session security	HttpOnly cookie architecture and CSRF protection	P1	Backend / Frontend
File protection	Quarantine and malware scanning	P1	Backend / Security
Observability	Logs, alerts, dashboards, request IDs, retention	P1	DevOps
Privacy operations	Retention, deletion, export, and voice-consent policy	P1	Management / Legal
Operational readiness	Support ownership, incident plan, user guide, training	P1	Product owner
Performance	Load test, API latency budget, regional placement review	P1	Engineering

P0 means required before the final production launch. P1 means complete before broad adoption or within a formally accepted, short, dated remediation window.

5. Step-by-Step Remediation Runbook

Phase 0 - Freeze and preserve evidence

1. Create a release branch from the reviewed commit and stop unrelated feature work.
2. Record the current production deployment ID, Git commit, Vercel environment names, Supabase project reference, and migration ledger.
3. Back up the production database and private storage before security changes.
4. Export current RLS policies and environment-variable names without exporting secret values.

Phase 1 - Close externally exploitable paths

1. Deploy the strict static-file allowlist and source-disclosure regression tests.
2. Set CRON_SECRET, make cron authentication fail closed, and validate schedule execution.
3. Move voice-note delivery behind authentication and ownership checks.
4. Sanitize global error responses and reduce the public health payload.
5. Add CSP and all required browser security headers in report-only staging, then enforce.

Phase 2 - Enforce data isolation at the database

1. Connect the actual production Supabase project to the review environment.
2. Change normal server queries from service-role to the user's bearer token.
3. Review every table, view, RPC, and storage bucket for RLS coverage.
4. Create repeatable Admin, Salesman A, and Salesman B integration fixtures.
5. Test list, read, insert, update, delete, upload, download, AI retrieval, export, and search across role boundaries.

Phase 3 - Harden identity, abuse controls, and files

1. Add durable login, AI, transcription, export, upload, and search limits.
2. Move sessions to HttpOnly secure cookies and add CSRF protection.
3. Remove the bootstrap password after validating Admin recovery.
4. Add malware quarantine and scanning for customer documents.
5. Rotate credentials that have been shared or exposed during development.

Phase 4 - Build operational safety

1. Enable searchable application and security logs with request IDs.
2. Create alerts for elevated 401/403/429/500 rates, cron failures, auth anomalies, storage failures, and database saturation.
3. Run and document a full backup restore into staging.
4. Define incident severity, on-call ownership, escalation, customer communication, and evidence preservation.
5. Confirm data retention and deletion rules for leads, notes, attachments, recordings, AI history, and audit events.

Phase 5 - Staging verification and user acceptance

1. Apply every pending migration to staging using the same release procedure planned for production.
2. Run automated tests, security regression tests, browser smoke tests, accessibility checks, and mobile tests.
3. Test Admin and Salesman workflows with production-like data but no real credentials or personal data.
4. Run a modest concurrency and export load test and verify Vercel/Supabase limits.
5. Obtain product-owner, security, database, and operations sign-off.

Phase 6 - Controlled production release

1. Deploy the exact signed/tagged commit validated in staging.
2. Apply migrations in a documented order with a tested rollback decision point.
3. Run the production smoke matrix in Section 8 immediately after deployment.
4. Monitor errors, latency, authentication failures, cron, AI spend, and database performance for at least 24 hours.
5. Keep a rollback deployment and database recovery procedure immediately available.

6. Required Production Configuration

Configuration	Required production state	How to verify
SUPABASE_URL	Exact live project URL; encrypted in Vercel.	Compare project reference with Supabase dashboard and health telemetry.
SUPABASE_ANON_KEY	Live publishable/anon key only.	Decode project reference; verify no service privileges.
SUPABASE_SERVICE_ROLE_KEY	Encrypted; server-only; explicit privileged calls only.	Search client bundle and network traffic; key must never appear.
CRON_SECRET	Random 32+ byte secret configured in production and scheduler.	Wrong/missing token fails; scheduled invocation succeeds.
ADMIN_BOOTSTRAP_PASSWORD	Removed after Admin creation.	Vercel production environment no longer lists it.
AI provider keys	Encrypted, scoped, rotated, spend limits enabled.	Provider dashboard alerts and quota policy demonstrated.
Google/Hunter keys	Restricted by API and usage; server-only.	Provider restrictions and billing alerts reviewed.
Session cookies	Secure, HttpOnly, SameSite; short access lifetime.	Browser storage and Set-Cookie inspection.
Supabase RLS	Enabled and tested on every business table.	Policy inventory plus cross-user automated test evidence.
Storage buckets	Private; signed URLs; ownership policies.	Anonymous download denied; expired signed URL denied.
Backups/PITR	Configured to business RPO/RTO.	Successful timed restore into staging.
Vercel headers	CSP, HSTS, nosniff, referrer, permissions, framing.	Automated header test against production.
Logging	Request IDs, redaction, retention, access control.	Find a synthetic failure by request ID.
Domains/TLS	Approved production domain, HTTPS-only, redirect policy.	External TLS and redirect test.

7. Go-Live Gate Checklist

Gate	Evidence required	Owner	Status
P0-01	Source files and repository metadata cannot be downloaded.	Security	NOT SIGNED
P0-02	Cron rejects missing and invalid credentials with no side effects.	Backend	NOT SIGNED
P0-03	Voice recordings require authentication and record-level authorization.	Backend	NOT SIGNED
P0-04	Normal queries use user identity; production RLS isolation tests pass.	Database	NOT SIGNED
P0-05	Security headers are enforced with no broken CRM workflow.	Frontend	NOT SIGNED
P0-06	Durable rate limits protect login and expensive endpoints.	DevOps	NOT SIGNED
P0-07	All production migrations are applied and schema drift is zero.	Database	NOT SIGNED
P0-08	Backup and restore drill meets the agreed RPO and RTO.	Operations	NOT SIGNED
P0-09	Release commit is clean, tagged, reproducible, and deployed.	Release	NOT SIGNED
P0-10	Admin and two-Salesman adversarial role matrix passes.	QA	NOT SIGNED
P0-11	Production logs and alerts are accessible to named responders.	Operations	NOT SIGNED
P0-12	No critical or high unresolved defects remain.	Management	NOT SIGNED

Release rule: no P0 item may be marked complete based only on a code change. Each item requires test evidence from staging or production, an owner, a date, and a reviewer.

8. Final Verification Matrix

Test area	Required scenarios	Pass evidence
Authentication	Valid login, invalid login, lockout/rate limit, logout, expired session, revoked user.	HTTP results, screenshots, security logs.
Role isolation	Admin, Salesman A, Salesman B across leads, tasks, activity, attachments, AI, exports.	Automated matrix with denied cross-user cases.
Dashboard	Counts match source records; all summary modals match totals; filters and pagination.	Reconciliation output and screenshots.
Pipeline	Search, every column filter, combined filters, sorting, paging, export, row open.	Browser test and exported row-count check.
Lead details	Tabs, edit, call/email, activity modal, notes, PMR, reminders, AI summary.	Desktop/mobile smoke recordings.
Activities	Create/edit, attachment upload, voice note, deletion request, Admin approval.	Audit trail and role result.
Tasks/report	Required field states, voice note, draft, submit, immutable trail, Admin review.	Submission record and audit events.
Files	Allowed files, blocked files, oversized files, malware test, unauthorized download.	Scanner and HTTP results.
AI Assistant	Read-only queries, confirmation for writes, role scope, rate limit, history privacy.	Prompt matrix and action logs.
Accessibility	Keyboard navigation, focus trap, labels, contrast, zoom 100/125/150 percent.	Automated scan plus manual checklist.
Responsive	Laptop, tablet, iPhone-sized viewport, no clipped text or page overflow.	Screenshots for Admin and Salesman.
Recovery	Rollback deployment and database restore.	Timed rehearsal notes.

Minimum automated commands

- npm run check
- npm test
- npm run build
- Production security regression script for public files, headers, protected endpoints, and rate limits
- Production smoke script for page, /api/health, login, role checks, and critical workflows

9. Launch Ownership and Sign-Off

Role	Required approval statement	Name / date
Engineering lead	The deployed commit matches the reviewed release and all P0 code fixes are present.	
Database owner	RLS, migrations, backup, restore, storage policies, and data isolation are verified.	
Security reviewer	All critical/high findings are closed and production regression tests pass.	
Product owner	Admin and Salesman workflows meet acceptance criteria with no missing business behavior.	
Operations owner	Monitoring, alerts, on-call ownership, rollback, and incident response are operational.	
Management sponsor	Residual risks are understood and final production launch is approved.	

Residual risk statement

At the time of this review, residual risk is unacceptable for final launch because four launch blockers remain unresolved and the live Supabase security posture has not been independently verified. After remediation, this document should be updated with evidence links, owners, completion dates, and a final decision.

Recommended next action

Begin a dedicated security-hardening release with F-01 through F-04 first. Do not combine it with unrelated UI work. Re-run the complete adversarial and role-isolation test after deployment before approving the live implementation.

End of report